



COMPUTER SECURITY

Lecture 5: Programs and OS Security

Prof. Dr. Noha Hikal

**Information Technology Dept.
Vice dean for Community Services and Environmental Development**

Operating Systems

- An operating system allows different users to access different resources in a **shared way**
- The operating system needs to control this sharing and provide an interface to allow this access
- **Identification** and **authentication** are required for this access control

History

- Operating systems evolved as a way to allow multiple users use the same hardware
 - OS makes resources available to users if required by them and permitted by some policy
 - OS also protects users from each other
 - Attacks, mistakes, resource overconsumption
-
- Even for a single-user OS, protecting a user from him/herself is a good thing

Protection in General-Purpose OS

OS system has two goals:

- Controlling shared access.
- Implementing an interface to allow that access.

Underneath those goals are support activities:

- Identification and authentication
- Naming
- Filing objects
- Scheduling
- Communication among processes
- Reusing objects.

*** Each of them has security implications.

Protection in General-Purpose OS

OS:

- SIMPLE SUPPORTING A SINGLE TASK AT A TIME.
- COMPLEX SUPPORTING MULTIUSER AND MULTITASKING.

*** NATURALLY, SECURITY CONSIDERATIONS INCREASE AS OS BECOME MORE COMPLEX.

Protected Objects

The rise of multiprogramming meant that several aspects of a computing system required protection:

- Memory.
 - Sharable i/o devices, such as disks.
 - Serially reusable i/o devices, such as printers and tape drives.
 - Sharable programs and sub-procedures.
-
- Networks.
 - Sharable data.

Security Methods of OS

The basis of protection is separation: keeping one user's objects separate from other users. That separation in an OS can occur in several ways:

- *Physical separation*, in which different processes use different physical objects. It is easy to implement, but expensive and inefficient
- *Temporal separation*, in which processes having different security requirements are executed at different times.

Security Methods of OS (cont.)

- *Logical separation*, in which users operate under the illusion that no other processes exist, as when an operating system constrains a program's accesses so that the program cannot access objects outside its permitted domain.
 - *Cryptographic separation*, in which processes conceal their data and computations in such a way that they are unintelligible to outside processes. (It is more **complex**.)
- *** A combination of these separations is possible.

Separation and Sharing

Separation is half of the answer. We want to separate users and their objects, but we also want to be able to provide sharing for some of those objects. OS can support separation and sharing in several ways, offering protection at any of several levels.

-
- *Do not protect*. OS with no protection is appropriate when sensitive procedures are being run at separate times.

Separation and Sharing (cont.)

- ***Isolate***. When OS provides isolation, different processes running concurrently are unaware of the presence of each other. Each process has its own address space, files, and other objects.
 - ***Share all or share nothing***. With this form of protection, the owner of an object declares it to be public or private.
-

Separation and Sharing (cont.)

- *Share via access limitation*. With protection by access limitation, the OS checks the allowability of each user's potential access to an object. That is, access control is implemented for a specific user and a specific object. The OS acts as a guard between users and objects, ensuring that only authorized accesses occur.
-

Separation and Sharing (cont.)

- *Share by capabilities*. An extension of limited access sharing, this form of protection allows dynamic creation of sharing rights for objects.
 - *Limit use of an object*. This form of protection limits not just the access to an object but the use made of that object after it has been accessed.
-

Access control

- In general, access control has three goals:
- Check every access: else OS might fail to notice that access has been revoked
- Enforce least privilege: grant program access only to smallest number of objects required to perform a task
- Access to additional objects might be harmless under normal circumstances, but disastrous in special cases
- Verify acceptable use: limit types of activity that can be performed on an object
- E.G., For integrity reasons

User authentication

- Computer systems often have to **identify** and **authenticate** users before **authorizing** them
- Identification: Who are you?
- Authentication: Prove it!
- Identification and authentication is easy among people that know each other
- For your friends, you do it based on their face or voice
- More difficult for computers to authenticate people sitting in front of them
- Even more difficult for computers to authenticate people accessing them remotely

User authentication

- OS bases much of its protection on identifying a user of the system.
 - Authentication mechanisms use any of three qualities to confirm a user's identity:
 - something the user knows, s.A. Passwords and PIN.
 - Something the user has, s.A. Cards and physical keys.
 - Something the user is. authenticators, called biometrics, and based on a physical characteristic of the user, such as a fingerprint and pattern of a person's voice.
 - Something about the user's context
 - Location, time
- *** Two or more forms can be combined for more solid authentication.

User authentication (cont.)

- SOMETHING THE USER IS. AUTHENTICATORS, CALLED BIOMETRICS, AND BASED ON A PHYSICAL CHARACTERISTIC OF THE USER, SUCH AS A FINGERPRINT AND PATTERN OF A PERSON'S VOICE.
 - - SOMETHING ABOUT THE USER'S CONTEXT
 - LOCATION, TIME
-

*** TWO OR MORE FORMS CAN BE COMBINED FOR MORE SOLID AUTHENTICATION.

Passwords as Authenticators

- Pws are widely used for authentication.
- Other information can be used in addition to pw, s.A. Access time and terminal.
- Pws suffer from some difficulties of use:
 - **loss**. Depending on how the passwords are implemented, it is possible that no one will be able to replace a lost or forgotten password. If the user loses the password, a new one must be assigned.
 - **Use**. Supplying a password for each access to a file can be inconvenient and time consuming.

Passwords as Authenticators (cont.)

- **Disclosure.** If a password is disclosed to an unauthorized individual, the file becomes immediately accessible. If the user then changes the password, all other legitimate users must be informed of the new password.
 - **Revocation.** To revoke one user's access right to a file, someone must change the password, thereby causing the same problems as disclosure.
-

Attacks on Passwords

Here are some ways you might be able to determine a user's password:

- Try all possible passwords.
 - Try frequently used passwords.
 - Try passwords likely for the user.
-
- Search for the system list of passwords.
 - Ask the user.

Exhaustive Attack

- **Exhaustive** or **brute force attack**, the attacker tries all possible passwords.
- The number of possible passwords depends on the implementation of the system.

E.G.

If passwords are words consisting of the 26 characters a..Z and can be of any length from 1 to 8 characters, then the system as a whole has $26^1 + 26^2 + \dots + 26^8 = \text{about } 5 * 10^{12}$ possible passwords.

Encrypted Password File

To foil an intruder seeking passwords in plain sight, encrypt them:

- Conventional encryption, but still some user(s) can decrypt them.
- Hash function/one-way ciphers.
A problem: what if two users choose the same pw and one of them see the hash value of the other user?

A solution: add to the pw a unique generated number to the pw before hashing.

Guidelines for PW Selection Criteria

- Use characters other than just AZ.
 - Choose long passwords.
 - Avoid actual names or words.
 - Choose an unlikely password.
 - Change the password regularly.
-
- Don't write it down.
 - Don't tell anyone else.

Biometrics: Authentication Not Using Passwords

- Biometrics are biological authenticators, based on some physical characteristic of the human body, s.A.
 - Fingerprints
 - retina
 - handwriting
 - hand geometry
 - voice
 - face.
-
- Advantage over pw: a biometric cannot be lost, stolen, forgotten, forged and is always available.

Problems with Biometrics

- Biometrics are relatively new, and some people find their use intrusive.
 - Biometric recognition devices are costly.
 - All biometric readers use sampling and establish a threshold for when a match is close enough to accept.
-
- Biometrics can become a single point of failure.

Problems with Biometrics (cont.)

- Although equipment is improving, there are still false readings.
 - The speed at which a recognition must be done limits accuracy.
 - Although we like to think of biometrics as unique parts of an individual, forgeries are possible.
-

THANK YOU

